Vulnerability Assessment Report

Generated automatically from the markdown analysis report

A - Résumé Exécutif

Après analyse, déduplication et consolidation des résultats, 3 vulnérabilités ont été retenues dans ce rapport, dont 2 sont prioritaires. Criticité recalculée après déduplication et priorisation : 24/100 — Niveau : FAIBLE. Niveau source du scan : medium. Cible analysée : https://themewagon.com/ (wordpress 6.8.3). Scan effectué le : 2026-02-23 13:10:43.448000.

B - Vulnérabilités Prioritaires

Content Security Policy (CSP) Header Not Set

* Description : La politique de sécurité de contenu (CSP) est une couche de sécurité supplémentaire qui aide à détecter et à atténuer certains types d'attaques, notamment les attaques de scriptage inter-site (XSS) et les attaques d'injection de données.
* Référence :
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- https://www.w3.org/TR/CSP/
- https://w3c.github.io/webappsec-csp/
- https://web.dev/articles/csp
- https://caniuse.com/#feat=contentsecuritypolicy
- https://content-security-policy.com/
* Catégorie OWASP : A05:2021 - Security Misconfiguration
* Recommandation technique : Définir une politique CSP de base avec default-src 'self' et déclarer explicitement les directives nécessaires comme script-src, style-src, img-src, font-src et frame-ancestors.
* Vérification :
- Exécuter curl -I https://[site] | grep -i content-security-policy
- Contrôler la présence de l'en-tête Content-Security-Policy.
- Tester l'application pour détecter d'éventuelles régressions fonctionnelles liées à la CSP.

Sub Resource Integrity Attribute Missing

* Description : L'attribut d'intégrité des ressources est manquant sur un script ou un lien servi par un serveur externe. L'attribut d'intégrité empêche un attaquant qui a accès à ce serveur d'injecter un contenu malveillant.
* Référence : https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
* Catégorie OWASP : A08:2021 - Software and Data Integrity Failures
* Recommandation technique : Identifier les scripts et les feuilles CSS chargés depuis des domaines externes et ajouter l'attribut integrity et crossorigin="anonymous" sur les ressources stables et versionnées.
* Vérification :
- Inspecter le code source HTML : curl -s https://[site] | grep -i 'integrity='
- Vérifier que chaque balise script et link externe contient l'attribut integrity et crossorigin.
- Recalculer le hash en cas de mise à jour de la dépendance.

C - Plan de remédiation

1. **Content Security Policy (CSP) Header Not Set** : Définir une politique CSP de base avec default-src 'self' et déclarer explicitement les directives nécessaires comme script-src, style-src, img-src, font-src et frame-ancestors.
2. **Sub Resource Integrity Attribute Missing** : Identifier les scripts et les feuilles CSS chargés depuis des domaines externes et ajouter l'attribut integrity et crossorigin="anonymous" sur les ressources stables et versionnées.

D - Conclusion

La criticité recalculée après déduplication et priorisation est FAIBLE. Le niveau de risque brut remonté par la sou
est medium. L'action prioritaire la plus critique est de définir une politique CSP de base avec default-src 'self'

ERROR fo
Invalid do

explicitement les directives nécessaires comme script-src, style-src, img-src, font-src et frame-ancestors. Cette action doit être effectuée dans les 90 jours.

```
## Tableau de synthèse des vulnérabilités

| 🔴 Critique | 🟠 Élevé | 🟡 Moyen | 🟢 Faible | ℹ️ Info |
|:---:|:---:|:---:|:---:|:---:|
| 0 | 0 | 2 | 1 | 30 |

⚠️ *En sus : 0 élevé(s) et 0 moyen(s) potentiels détectés (version non confirmée — voir Annexe A)*

**Score de risque global : 24/100 — Niveau : FAIBLE**

**Éléments techniques listés en annexe :** 33 | **Vulnérabilités retenues dans le rapport :** 3 |
**Prioritaires (section B) :** 2

> ℹ️ *Les chiffres ci-dessus sont calculés après déduplication.
> Les findings informatifs (Info) sont exclus du comptage des vulnérabilités.*
```

Annexe A - Vulnérabilités potentielles détectées mais non retenues dans le total principal (version non confirmée)

Priorité	Type	Severity	Risk	Confidence	Titre	Cible	Preuve	alertRef	Note

Annexe B - Liste complète des findings dédupliqués (TOUS)

Priorité	Type	Severity	Risk	Confidence	Titre	Cible	Preuve	alertRef	Note
P3	vulnerability	medium	Medium	High	Content Security Policy (CSP) Header Not Set	https://themewagon.com/	—	10038-1	—
P3	vulnerability	medium	Medium	High	Sub Resource Integrity Attribute Missing	https://themewagon.com/	, ,	90003	—
P4	vulnerability	low	Low	Medium	Cross-Domain JavaScript Source File Inclusion	https://themewagon.com/	,	10017	—
P5	information	info	—	—	Plugin détecté : automattic-for-agencies-client	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : blaze-ads	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : contact-form-7	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : duracelltomi-google-tag-manager	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : if-menu	https://themewagon.com/	—		Plugin installé — aucune CVE

Priorité	Type	Severity	Risk	Confidence	Titre	Cible	Preuve	alertRef	Note
									connue associée
P5	information	info	—	—	Plugin détecté : jetpack	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : jetpack-search	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : mainichi-shopify-products-connect	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : redirection	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : schema-and-structured-data-for-wp	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : w3-total-cache	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : woo-custom-related-products	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : woocommerce	https://themewagon.com/	—		Plugin installé — aucune CVE

Priorité	Type	Severity	Risk	Confidence	Titre	Cible	Preuve	alertRef	Note
									connue associée
P5	information	info	—	—	Plugin détecté : woocommerce-gateway-stripe	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : wordpress-seo	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : wp-ses	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Plugin détecté : wp-store-lite	https://themewagon.com/	—		Plugin installé — aucune CVE connue associée
P5	information	info	—	—	Technologie détectée : Cloudflare	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : Google Tag Manager	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : HSTS	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : HTTP/3	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze

Priorité	Type	Severity	Risk	Confidence	Titre	Cible	Preuve	alertRef	Note
P5	information	info	—	—	Technologie détectée : MySQL	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : PHP	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : W3 Total Cache	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : WooCommerce	https://themewagon.com/	10.3.0		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : WordPress	https://themewagon.com/	Version non fournie, 6.8.3		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : Yoast SEO	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : Yoast SEO Premium	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : YouTube	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze
P5	information	info	—	—	Technologie détectée : reCAPTCHA	https://themewagon.com/	Version non fournie		Technologie détectée via Webanalyze